

NAVIGATING THE LATEST UPDATES IN SAUDI DATA PROTECTION: PDPL COMPLIANCE AND IMPLEMENTATION

I. RECENT UPDATES SINCE AUGUST 2024

Since the Personal Data Protection Law (“PDPL”) came into effect in September 2023, Saudi Arabia has released several key updates that significantly impact data protection practices. In August 2024, new guidelines and regulations were introduced, setting the stage for compliance in the evolving legal landscape. This article examines these recent updates and provides a comprehensive guide for businesses to align with the latest requirements.

Minimum Personal Data Guideline (August 2024)

The Minimum Personal Data Guideline, issued in August 2024, underscores the importance of collecting only the minimal amount of personal data necessary for processing. This guideline emphasizes data minimization, requiring organizations to justify every data point they collect (Minimum Personal Data Guideline, Section 2). It directly aligns with the PDPL’s broader goal of limiting the exposure of personal data to unnecessary risks.

Personal Data Destruction, Anonymization, and Pseudonymization Guideline (August 2024)

This guideline, also released in August 2024, provides explicit instructions on how personal data should be destroyed or anonymized when it is no longer needed. It outlines specific technical and organizational measures to ensure that destroyed or anonymized data cannot be re-identified. This is particularly critical for sectors handling sensitive personal data (Destruction Guideline, Section 3). Anonymization techniques must adhere to the principle of permanent de-identification, making it impossible to trace data back to individuals (Section 4).

Personal Data Disclosure Cases Guideline (August 2024)

The Personal Data Disclosure Cases Guideline introduces new scenarios in which personal data can be disclosed legally. These include disclosures for public interest, scientific research, or judicial purposes (Personal Data Disclosure Cases Guideline, Section 3). This guideline is essential for companies dealing with frequent legal or governmental requests for data.

Personal Data Processing Activities Records Guideline (August 2024)

With the growing complexity of data processing operations, the Personal Data Processing Activities Records Guideline mandates that all data controllers and processors maintain detailed records of their processing activities (Personal Data Processing Activities Records Guideline, Section 2). These records must be kept for at least five years after the cessation of processing activities. Moreover, organizations are now required to categorize personal data according to risk levels, ensuring that highly sensitive data is monitored and documented more rigorously.

Regulation on the Transfer of Personal Data Outside the Kingdom (August 2024)

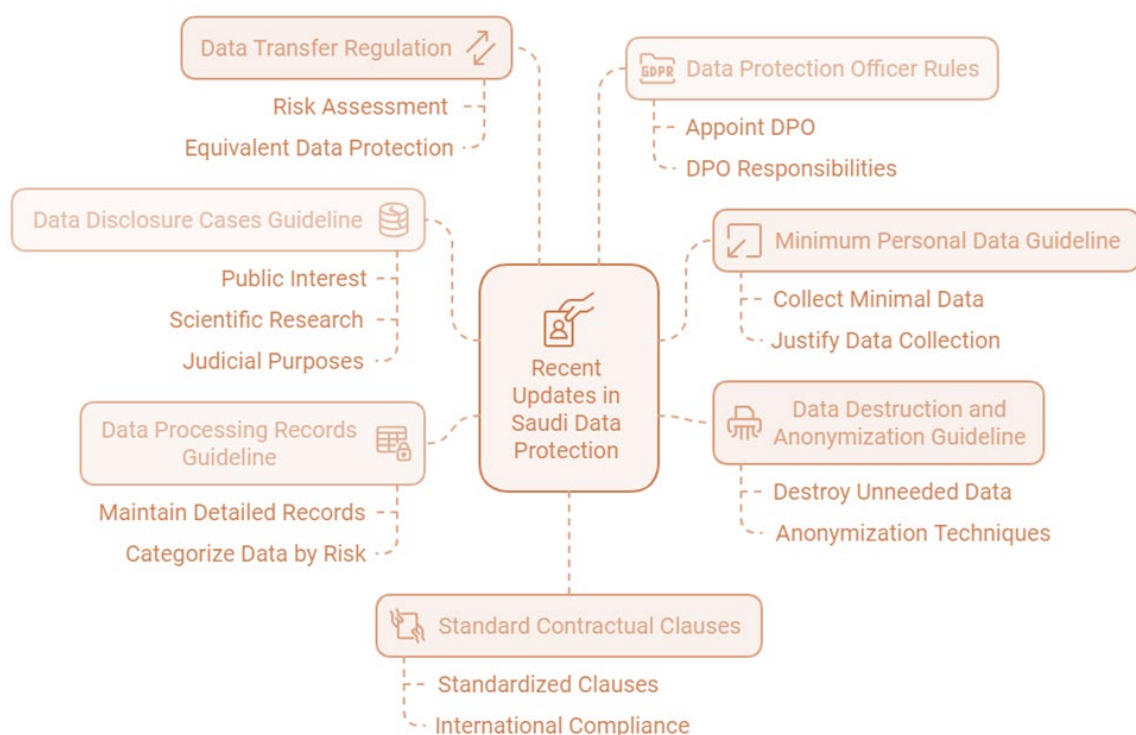
The Regulation on the Transfer of Personal Data Outside the Kingdom, updated in August 2024, provides stricter guidelines for transferring personal data abroad. It outlines that data transfers must meet specific criteria, such as an equivalent level of data protection in the receiving country or explicit consent from the data subject (Regulation on Transfer Outside the Kingdom, Article 3). A key addition is the requirement for a risk assessment before any transfer, ensuring that the risks to personal data are thoroughly evaluated (Article 8).

Rules for Appointing a Data Protection Officer (August 2024)

The Rules for Appointing a Data Protection Officer (DPO) have been clarified, requiring organizations that process large volumes of personal data or sensitive data to appoint a DPO (Rules for Appointing DPO, Article 4). The DPO is responsible for overseeing the organization's data protection strategies, monitoring compliance, and acting as the main point of contact for both data subjects and SDAIA.

Standard Contractual Clauses for Personal Data Transfer (September 2024)

Issued in September 2024, the Standard Contractual Clauses (SCCs) offer a new mechanism for ensuring compliance with cross-border data transfers. The SCCs provide standardized clauses that can be included in contracts between Saudi entities and international partners, ensuring that foreign recipients of personal data adhere to the PDPL's strict standards (SCCs, Article 3). This update is particularly crucial for multinational organizations operating across borders, as it simplifies compliance with international data transfer regulations.



II. WHAT SHOULD COMPANIES KNOW AND DO?

This article is designed to help companies generally understand the PDPL and the relevant guidelines, offering a step-by-step approach to navigate the regulations. Companies must understand the key definitions and principles in the PDPL which have remained largely unchanged even with the updated literature surrounding it.

What is Personal Data?

Under the PDPL, personal data refers to any information that can directly or indirectly identify a person, including names, contact details, national ID numbers, IP addresses, and more. This data must be protected throughout its lifecycle (PDPL, Article 1).

Sensitive Data

Sensitive data includes information related to racial or ethnic origin, religious beliefs, political opinions, health data, and biometric information (PDPL, Article 1). Sensitive data requires higher levels of protection, such as encryption and anonymization during processing and storage (Destruction Guideline, Section 4).

Scope

The PDPL applies to all entities, whether based in Saudi Arabia or abroad, that process the personal data of individuals within the Kingdom (PDPL, Article 2). This extraterritorial reach means international companies must also comply if they handle Saudi citizens' data.

Identify Lawful Grounds for Processing

There are several lawful grounds for processing personal data under the PDPL:

- Explicit consent from the data subject (PDPL, Article 5).
- Performance of a contract, such as fulfilling a service agreement (PDPL, Article 6).
- Legal obligations, where processing is required by law (PDPL Implementing Regulations, Article 7).
- Vital interests, such as protecting someone's life or safety.
- Public interest, particularly when processing is necessary for state functions or legal proceedings.

Companies must identify which lawful basis applies to each processing activity and ensure that documentation is in place to demonstrate compliance.

Obtain and Manage Consent

If consent is used as the lawful basis for processing, the company must ensure that it is explicit, specific, informed, and freely given (PDPL, Article 5). The Minimum Personal Data Guideline emphasizes that companies should only collect data that is necessary for the stated purpose (Minimum Personal Data Guideline, Section 2). Tools such as Consent Management Platforms (CMPs) can be useful for tracking consent records and ensuring compliance.

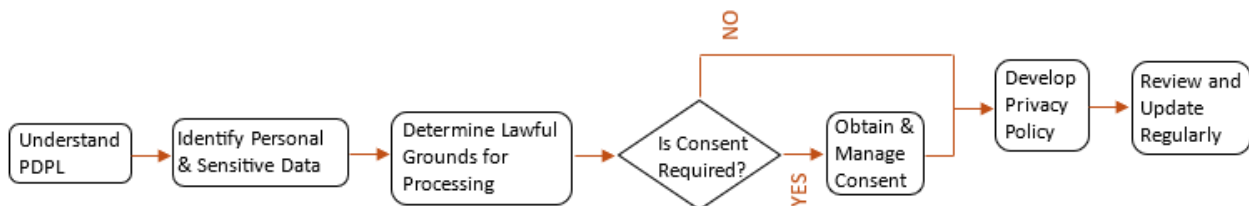
Develop and Maintain a Comprehensive Privacy Policy

A compliant privacy policy must cover the following aspects (PDPL Implementing Regulations, Article 7):

- Purpose of data collection.
- Categories of personal data being processed.
- The lawful basis for processing (e.g., consent, contract).
- Details of any third-party data sharing.
- Rights of the data subject, including access, correction, and deletion rights (PDPL, Article 4).
- Information on how to withdraw consent.

Review and Update Regularly

Companies should regularly review and update their privacy policies to reflect changes in processing activities, legal developments, or internal processes. The policy must be accessible on all platforms where personal data is collected (e.g., websites, mobile apps).



III. EXAMPLE SCENARIOS

Scenario 1: Cross-Border Data Transfer Without Adequate Safeguards

Problem:

ABC Company, a Saudi-based e-commerce platform, collects and processes personal data from its customers, including names, addresses, payment details, and IP addresses. Recently, ABC signed a contract with a foreign cloud service provider located outside Saudi Arabia to store customer data and process it for marketing and analytics purposes.

However, the foreign country where the cloud service provider is located does not have equivalent data protection laws. ABC Company did not obtain explicit consent from its customers for this cross-border transfer, nor did it conduct a risk assessment. A few customers discovered that their data was being processed overseas and have filed complaints with Saudi Data and Artificial Intelligence Authority (“SDAIA”).

Questions:

Has ABC Company breached the PDPL? What steps should ABC Company take to ensure compliance with the PDPL when transferring data abroad?

Answer:

Yes, ABC Company has breached the PDPL by transferring customer data outside Saudi Arabia without adequate safeguards or explicit consent, as required by the law.

Step 1: Understanding PDPL Requirements for Cross-Border Data Transfers

Under the PDPL, personal data cannot be transferred outside the Kingdom unless certain conditions are met (PDPL, Article 29). These include:

- Explicit consent from the data subject for the transfer.
- The receiving country must offer an equivalent level of data protection.
- A risk assessment must be conducted to evaluate the impact of the transfer on the data subjects (Regulation on Transfer Outside the Kingdom, Article 8).

Step 2: Implementing Standard Contractual Clauses (SCCs)

ABC Company should implement Standard Contractual Clauses (SCCs) to ensure that the foreign service provider complies with the PDPL (SCCs, Article 3).

Step 3: Conducting a Risk Assessment

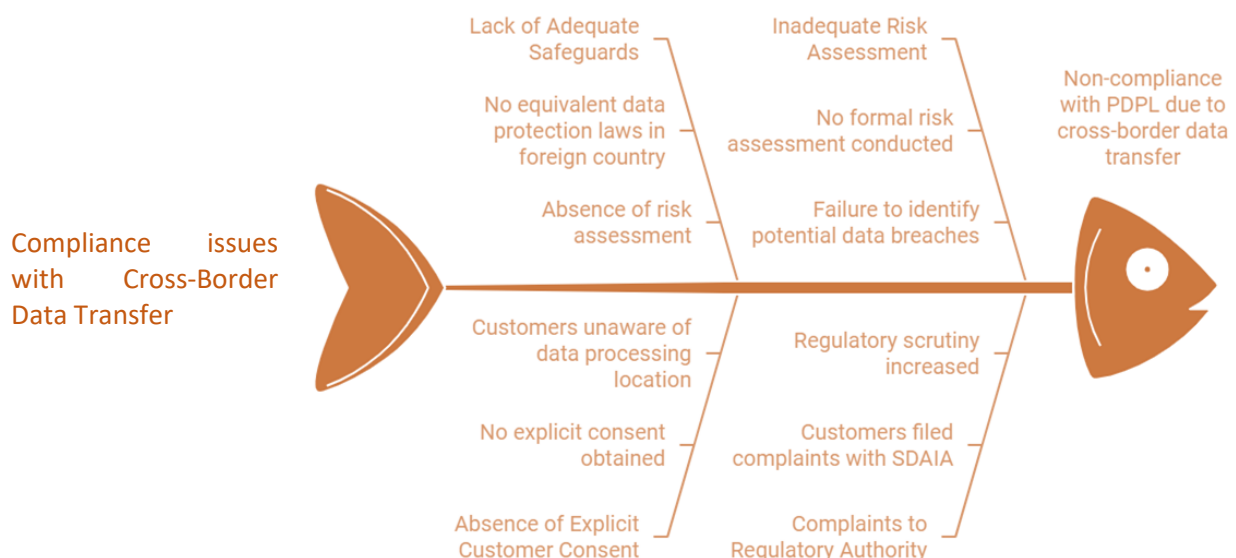
ABC Company must conduct a risk assessment to evaluate the data protection framework in the foreign country and the risks posed to data subjects.

Step 4: Obtain Explicit Consent

ABC Company must obtain explicit consent from its customers for the cross-border transfer and update its privacy policy accordingly.

Step 5: Review Contracts with Third-Party Service Providers

ABC Company must review its contract with the foreign cloud service provider to ensure it is compliant with Saudi data protection standards.



Scenario 2: Data Subject Requests for Access and Deletion

Problem:

XYZ Insurance, a large insurance company operating in Saudi Arabia, processes the personal data of its policyholders, including sensitive health information. One of XYZ's customers, Ahmad, requested access to his personal data, including medical records, to review the data that XYZ holds on him. Additionally, Ahmad has decided to switch insurance providers and has asked XYZ to delete all his personal data, citing the fact that he no longer requires the company's services.

XYZ Insurance is unsure whether it is legally required to comply with both the access and deletion requests, especially since the data includes sensitive health information, which may be required for regulatory or legal purposes.

Questions:

Is XYZ Insurance required to grant Ahmad access to his personal data? Can XYZ refuse the deletion request under the PDPL? How should XYZ respond to Ahmad's requests while complying with PDPL and related guidelines?

Answer:

Step 1: Data Subject's Right to Access

Under the PDPL, Ahmad has the right to access his personal data, and XYZ must provide him with a copy of his data upon request (PDPL, Article 4).

Step 2: Assessing the Deletion Request

While Ahmad has the right to request the deletion of his personal data, XYZ may retain the data if required by law or regulation for a certain period (PDPL, Article 6).

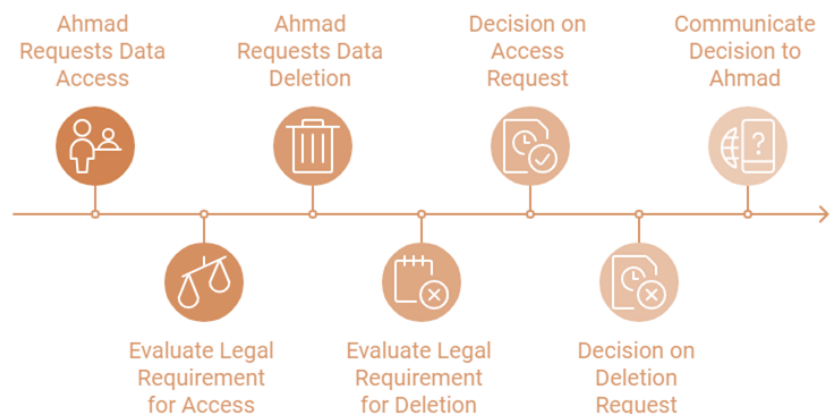
Step 3: Providing a Response to Ahmad

XYZ should grant access to Ahmad's data and evaluate the deletion request based on legal and regulatory retention obligations.

Step 4: Updating Internal Policies

XYZ should ensure it has clear internal processes for handling access and deletion requests and secure retention of sensitive data.

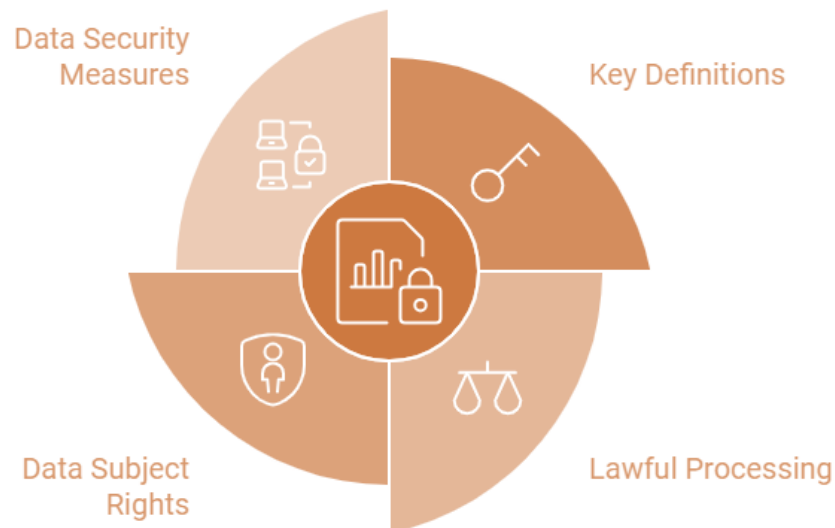
Handling Data Subject Requests at XYZ Insurance



IV. CONCLUSION

Navigating Saudi Arabia's PDPL and its associated regulations can be complex, but with the right approach, and tailored legal advice, companies can ensure compliance while safeguarding personal data. By following the steps outlined in this article—understanding key definitions, securing lawful processing, protecting data subject rights, and implementing strong data security measures—organizations can not only avoid penalties but also build trust and demonstrate their commitment to data privacy. As data privacy continues to evolve globally, staying ahead of regulatory changes and embedding privacy into your company's culture will set the foundation for long-term success.

Navigating Saudi Arabia's PDPL



Points of Contact:



Wissam Hachem
Partner
Wissam.hachem@blkpartners.com



Mohammed Yasin
Senior Associate
mohammed.yasin@blkpartners.com

This article can also be accessed at: www.blkpartners.com